

VulnTriage

AI-Assisted Vulnerability Triage Report

Report Title:	Auto Scan Report — http://localhost:3000 — 12 Jul 2026
Generated:	14 July 2026, 10:31 UTC
Analyst:	analyst
Total Findings:	16

Critical	High	Medium	Low
0	1	4	3

Executive Summary

This report presents the results of an automated vulnerability triage conducted using VulnTriage. A total of **16** unique findings were identified across **2** scanner source(s) (**nuclei, zap**). The analysis combines multi-scanner correlation, NVD enrichment, Random Forest ML priority prediction, and a composite six-factor confidence scoring engine to produce final classifications.

Classification Breakdown

Category	Count	%
Confirmed	4	25%
Needs Manual Verification	0	0%
Not Confirmed	4	25%
Unclassified	8	50%
Total	16	100%

Severity Breakdown

Category	Count	%
Critical	0	0%
High	1	6%
Medium	4	25%
Low	3	19%
Informational	8	50%
Total	16	100%

AI-Assisted Analysis

Generated by an AI model from the triaged findings. Review before acting.

Overview

The application's security posture is primarily threatened by a confirmed, high-severity SQL Injection vulnerability in the SQLite database, coupled with multiple missing defensive HTTP headers (CSP, Anti-clickjacking, and X-Content-Type-Options). Addressing the database injection vector and hardening server headers will significantly reduce the attack surface.

Key Findings Explained

SQL Injection - SQLite

Risk: An attacker can execute arbitrary SQL commands, potentially allowing them to bypass authentication, access, modify, or delete sensitive data in the SQLite database.

Fix: Implement parameterized queries (prepared statements) for all database operations instead of concatenating user input directly into SQL strings.

Content Security Policy (CSP) Header Not Set

Risk: The absence of a CSP header increases susceptibility to Cross-Site Scripting (XSS) and data injection attacks by allowing the browser to execute untrusted scripts.

Fix: Configure the web server to send a robust 'Content-Security-Policy' header that defines restricted, trusted sources for executable content.

Missing Anti-clickjacking Header

Risk: Without framing protections, the application can be embedded in an adversary's malicious site, enabling clickjacking attacks to trick users into executing unintended actions.

Fix: Set the 'X-Frame-Options' header to 'SAMEORIGIN' or 'DENY', and leverage the CSP 'frame-ancestors' directive.

X-Content-Type-Options Header Missing

Risk: Browsers may attempt to sniff response content types, which can lead to non-executable files (like uploaded images) being executed as scripts or stylesheets.

Fix: Configure the server to send the 'X-Content-Type-Options: nosniff' header with all responses.

Prioritised Actions

1. Refactor SQLite database queries to enforce parameterized input and eliminate the SQL injection vulnerability immediately.
2. Deploy a global configuration update to inject 'Content-Security-Policy', 'X-Frame-Options', and 'X-Content-Type-Options' security headers across all web assets.
3. Validate the lower-confidence, unconfirmed Medium findings, specifically 'Cross-Domain Misconfiguration' and 'Session ID in URL Rewrite', to rule out false positives.

Findings Detail

High Findings (1)

SQL Injection - SQLite

CVE	—	CWE	CWE-89
CVSS Score	7.5	Confidence	81/100
URL	http://localhost:3000/rest/products/search?q=%27%28	ML Priority	Critical
Classification	Vulnerability Confirmed	Scanners	1 (zap)
Why this classification: Confirmed (81/100). PoC actively confirmed the vulnerability — classification forced to Confirmed (score scaled into the 70-100 band).			
Description: SQL injection may be possible.			
Recommendation: Do not trust client side input, even if there is client side validation in place. In general, type check all data on the server side. If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?' If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries. If dat...			

Medium Findings (4)

#	Title	CVE	CVSS	Confidence	Classification	ML Priority
1	Content Security Policy (CSP) Header Not Set	—	5.0	79	Vulnerability Confirmed	Critical
2	Cross-Domain Misconfiguration	—	5.0	38	Vulnerability Not Confirmed	Medium
3	Missing Anti-clickjacking Header	—	5.0	84	Vulnerability Confirmed	Medium
4	Session ID in URL Rewrite	—	5.0	38	Vulnerability Not Confirmed	Medium

Low Findings (3)

#	Title	CVE	CVSS	Confidence	Classification	ML Priority
1	Private IP Disclosure	—	2.0	30	Vulnerability Not Confirmed	Medium
2	Timestamp Disclosure - Unix	—	2.0	30	Vulnerability Not Confirmed	Medium
3	X-Content-Type-Options Header Missing	—	2.0	78	Vulnerability Confirmed	Critical

Informational Findings (8)

#	Title	CVE	CVSS	Confidence	Classification	ML Priority
1	Information Disclosure - Suspicious Comments	—	—	18	Informational	Critical
2	Modern Web Application	—	—	8	Informational	Critical
3	Session Management Response Identified	—	—	8	Informational	Critical
4	User Agent Fuzzer	—	—	18	Informational	Critical
5	Public Swagger API - Detect	—	—	23	Informational	High
6	Dameng Database - Detect	—	—	8	Informational	Critical
7	LDAP Metadata - Enumeration	—	—	8	Informational	Critical
8	SNMPv3 Fingerprint - Detect	—	—	8	Informational	Critical

Machine Learning Analysis

The VulnTriage Random Forest classifier (200 estimators, pure NumPy implementation) was trained on NVD CVE translation records with CVSS v3 feature vectors. It predicts a priority label (Critical / High / Medium / Low) for each finding independently of the scanner-reported severity, using 10 normalised feature dimensions including CVSS base score, attack vector, attack complexity, privileges required, and impact metrics.

ML Priority Distribution

Priority	Count	% of ML-predicted
Critical	10	62.5%
High	1	6.2%
Medium	5	31.2%
Low	0	0.0%
Total	16	100%

Confidence Score Distribution

Confidence Band	Count	Threshold Action
High (>=70)	4	Confirmed
Medium (40-69)	0	Needs Review
Low (<40)	12	Not Confirmed

Proof-of-Concept Validation Results

PoC validation was performed on **16** findings (32 total checks). **4 confirmed**, 10 not confirmed, 18 skipped/error.

Finding	Check Type	Result	Evidence / Payload
SQL Injection - SQLite	sql_check	Not Confirmed	No SQL errors, boolean difference, or time delay observed across error/boolean/time-based probes. Manual verification re
	sql_check	CONFIRMED	Payload: 1'-- SQL error string detected in response (error-based). Payload : 1'-- Matched : SQLITE_ERROR
Content Security Policy (CSP) Header Not Set	header_check	Error	Error: HTTPConnectionPool(host='localhost', port=3000): Max retries exceeded with url:
	header_check	CONFIRMED	Missing security headers: ['strict-transport-security', 'content-security-policy']
Cross-Domain Misconfiguration	response_analysis	Error	Error: HTTPConnectionPool(host='localhost', port=3000): Max retries exceeded with url:
	response_analysis	Not Confirmed	Server: (not set) X-Powered-By: (not set) Versions disclosed: []
Missing Anti-clickjacking Header	header_check	Error	Error: HTTPConnectionPool(host='localhost', port=3000): Max retries exceeded with url:
	header_check	CONFIRMED	Missing security headers: ['strict-transport-security', 'x-frame-options', 'x-content-type-options', 'content-security-p
Session ID in URL Rewrite	payload_reflection	Error	Error: HTTPConnectionPool(host='localhost', port=3000): Max retries exceeded with url:
	payload_reflection	Not Confirmed	Payload: VT-PROBE-7x3k Marker 'VT-PROBE-7x3k' reflected in response: False
Private IP Disclosure	response_analysis	Error	Error: HTTPConnectionPool(host='localhost', port=3000): Max retries exceeded with url:
	response_analysis	Not Confirmed	Server: (not set) X-Powered-By: (not set) Versions disclosed: []
Timestamp Disclosure - Unix	response_analysis	Error	Error: HTTPConnectionPool(host='localhost', port=3000): Max retries exceeded with url:
	response_analysis	Not Confirmed	Server: (not set) X-Powered-By: (not set) Versions disclosed: []
X-Content-Type-Options Header Missing	header_check	Error	Error: HTTPConnectionPool(host='localhost', port=3000): Max retries exceeded with url:
	header_check	CONFIRMED	Missing security headers: ['strict-transport-security', 'x-frame-options', 'x-content-type-options', 'content-security-p
Information Disclosure - Suspicious Comments	response_analysis	Error	Error: HTTPConnectionPool(host='localhost', port=3000): Max retries exceeded with url:

Finding	Check Type	Result	Evidence / Payload
	response_analysis	Not Confirmed	Server: (not set) X-Powered-By: (not set) Versions disclosed: []
Modern Web Application	response_analysis	Error	Error: HTTPConnectionPool(host='localhost', port=3000): Max retries exceeded with url:
	response_analysis	Not Confirmed	Server: (not set) X-Powered-By: (not set) Versions disclosed: []
Session Management Response Identified	payload_reflection	Error	Error: HTTPConnectionPool(host='localhost', port=3000): Max retries exceeded with url:
	payload_reflection	Not Confirmed	Payload: VT-PROBE-7x3k Marker 'VT-PROBE-7x3k' reflected in response: False
User Agent Fuzzer	payload_reflection	Error	Error: HTTPConnectionPool(host='localhost', port=3000): Max retries exceeded with url:
	payload_reflection	Not Confirmed	Payload: VT-PROBE-7x3k Marker 'VT-PROBE-7x3k' reflected in response: False
Public Swagger API - Detect	response_analysis	Error	Error: HTTPConnectionPool(host='localhost', port=3000): Max retries exceeded with url:
	response_analysis	Not Confirmed	Server: (not set) X-Powered-By: (not set) Versions disclosed: []
Dameng Database - Detect	response_analysis	Skipped	Target host 'None' is outside the authorised PoC scope (localhost). Add it to POC_SCOPE to authorise.
	response_analysis	Skipped	Target host 'None' is outside the authorised PoC scope (localhost). Add it to POC_SCOPE to authorise.
LDAP Metadata - Enumeration	response_analysis	Skipped	Target host 'None' is outside the authorised PoC scope (localhost). Add it to POC_SCOPE to authorise.
	response_analysis	Skipped	Target host 'None' is outside the authorised PoC scope (localhost). Add it to POC_SCOPE to authorise.
SNMPv3 Fingerprint - Detect	response_analysis	Skipped	Target host 'None' is outside the authorised PoC scope (localhost). Add it to POC_SCOPE to authorise.
	response_analysis	Skipped	Target host 'None' is outside the authorised PoC scope (localhost). Add it to POC_SCOPE to authorise.

Note: 4 finding(s) confirmed by PoC have been automatically classified as **Confirmed** and their confidence scores set to ≥ 75 regardless of other factor weights.

Recommendations

Recommendations are prioritised by the CWE categories most frequently observed in this scan.

CWE-693 (2 findings) — See MITRE CWE advisory for remediation guidance.

CWE-497 (2 findings) — See MITRE CWE advisory for remediation guidance.

CWE-89 — SQL Injection (1 finding)

Use parameterised queries exclusively. Apply least-privilege DB accounts. Enable WAF SQL injection rules. Audit ORM usage for raw query construction.

CWE-264 (1 finding) — See MITRE CWE advisory for remediation guidance.

CWE-1021 (1 finding) — See MITRE CWE advisory for remediation guidance.

CWE-598 (1 finding) — See MITRE CWE advisory for remediation guidance.

CWE-615 (1 finding) — See MITRE CWE advisory for remediation guidance.

CWE-0 (1 finding) — See MITRE CWE advisory for remediation guidance.

CWE-200 — Information Disclosure (1 finding)

Suppress verbose error messages in production. Remove debug output. Review HTTP response headers for server version leakage.

General Best Practices

- Prioritise remediation of Critical and High severity findings within 24–48 hours.
- Review all 'Needs Manual Verification' findings before closing — these may contain true positives with limited scanner evidence.
- Re-scan after patching to confirm vulnerability resolution and avoid regression.
- Maintain a vulnerability disclosure policy and track Mean Time to Remediate (MTTR).
- Integrate SAST/DAST scanners into the CI/CD pipeline to detect regressions early.

Generated by VulnTriage AI-Assisted Vulnerability Triage System. This document is CONFIDENTIAL and intended for the authorised analyst only.